

The Technical Triage & Eviction "Cheat Sheet"

Target Audience: SOC Analysts, Incident Responders, and Security Engineers

I. Immediate Containment: The "Kill Chain"

- **Step 1: Atomic Session Revocation**
 - *Microsoft Graph:* `Revoke-MgUserSignInSession -UserId "dave@utility.org"`
 - *Azure CLI:* `az ad user revoke-sign-in-sessions --id "dave@utility.org"`
- **Step 2: MFA Cleanup**
 - Identify and delete all MFA methods (FIDO2, SMS, Push) via `Remove-MgUserAuthenticationMethod`.
- **Step 3: Strategic Password Reset**
 - Execute only *after* revocation is confirmed to prevent re-entry.

II. SIEM Hunting & Forensic Analysis

- **Residential Proxy Hunt (KQL):**
[SigninLogs | where ResultType == 0

| summarize IPCount = dcount(IPAddress), ASNs =
make_set(AutonomousSystemNumber) by UserPrincipalName, UserAgent

| where IPCount > 1]
- **JA4/TLS Mismatch (SPL):**
[index=network_logs sourcetype=zeek_ssl
| stats dc(ja4_fingerprint) as fingerprint_count by user_agent
| where fingerprint_count > 1]

III. Multi-Vendor Telemetry Logic

- **Palo Alto Prisma Access:** Filter for *auth-success* events where *source-hierarchy* is *Residential* or *Proxy*. Monitor for protocol downgrades from SAML to Legacy-MFA.
- **CrowdStrike Falcon:** Monitor *UserLogon* events where *LogonType=3* or *9* occurs immediately after a browser process (*chrome.exe*) accesses an external IP not associated with the IdP.